



TÀI LIỆU SOURCE CODE · ANTI-CHEAT CHO SERVER THE ISLE EVRIMA

Phát hiện gian lận và ghi log

Phần lõi của anti-cheat: tìm gì trên máy người chơi, tìm bằng cách nào, và mỗi finding được ghi thành log ra sao. Kèm luồng đăng nhập Steam + Discord trước khi người chơi được cấp quyền vào server.

PHIÊN BẢN TÀI LIỆU

1.0

NGÀY LẬP

26/09/2026

NỀN TẢNG

.NET 10 · C# · Windows 10/11

NỘI DUNG

- | | |
|----|---|
| 01 | Phạm vi và cấu trúc source code |
| 02 | Kiến trúc Scanner |
| 03 | Phát hiện qua tiến trình |
| 04 | Phát hiện qua file game |
| 05 | Dấu vết công cụ trên máy |
| 06 | Overlay lạ và HWID |
| 07 | Finding code, severity, observe/enforce |
| 08 | Ghi log: từ finding đến bằng chứng |
| 09 | Đăng nhập Steam + Discord, cấp quyền vào server |
| 10 | Wall-hack: module nào bắt được |

01 Phạm vi và cấu trúc source code

TÀI LIỆU ĐI SÂU

- **Thư viện phát hiện:** 9 module quét, cấu hình hoàn toàn bằng một file policy JSON.
- **Log:** mỗi finding có code, severity và bằng chứng; scan report; log lưu ở đâu và đọc thế nào.
- **HWID** và **đăng nhập Steam + Discord** trước khi cấp quyền vào server.

CHỈ NHẮC QUA

- Hạ tầng server: đồng bộ whitelist qua RCON/file, hết hạn lease, admin API.
- Admin dashboard, UI và đóng gói launcher.
- Phần phát hiện không phụ thuộc vào các phần trên: input là một policy JSON, output là một report JSON, nên gắn được vào launcher hay server có sẵn.

Cấu trúc source code

Toàn bộ module phát hiện nằm trong thư mục `launcher/IsleWarden.Core/`. Bảng dưới liệt kê theo tên file trong thư mục đó.

File	Vai trò
ĐIỀU PHỐI	
<code>Scanner.cs</code>	Chạy mọi module đã bật trong một lần quét, gom kết quả thành report.
<code>Policy.cs</code>	Định nghĩa policy: danh sách cấm, từ khoá, bật/tắt từng module, severity, chế độ observe/enforce.
<code>ScanContext.cs</code> · <code>SteamLocator.cs</code> · <code>VdfParser.cs</code>	Tìm thư mục cài game và build ID qua Steam (registry → <code>libraryfolders.vdf</code> → <code>appmanifest_376210.acf</code>).
<code>FileHashCache.cs</code> · <code>PathTemplate.cs</code>	Cache SHA-256 theo kích thước + thời điểm sửa file; thay <code>{GameDir}</code> và biến môi trường trong đường dẫn.
MODULE PHÁT HIỆN	
<code>ProcessScanner.cs</code> · <code>ProcessSource.cs</code>	Tiến trình bị cấm đang chạy (mục 3.1).
<code>ProcessInventoryScanner.cs</code>	Tên tiến trình chứa từ khoá đáng ngờ (3.2).
<code>ModuleScanner.cs</code> · <code>ModuleSource.cs</code>	DLL nạp vào tiến trình game (3.3).
<code>StartupOrderChecker.cs</code>	Game được mở trước launcher (3.4).
<code>FileIntegrityChecker.cs</code> · <code>AuthenticodeVerifier.cs</code>	Hash và chữ ký số của các file được bảo vệ (4.1).
<code>Baseline.cs</code> · <code>BaselineChecker.cs</code>	So toàn bộ file game với baseline của đúng bản build (4.2).
<code>FileScanner.cs</code>	File công cụ gian lận nằm trên ổ đĩa (5.1).
<code>ExecutionHistoryScanner.cs</code> · <code>PrefetchReader.cs</code>	Prefetch — lịch sử chạy chương trình của Windows (5.2).
<code>OverlayScanner.cs</code>	Cửa sổ lạ phủ lên game (6.1) — đã viết, chưa nối vào Scanner.
<code>DeviceFingerprint.cs</code> · <code>WmiIdentifiers.cs</code>	HWID để ban theo máy (6.2).

File	Vai trò
LOG VÀ GIAO THỨC	
Finding.cs · FindingCodes.cs · Severity.cs · ScanReport.cs	Finding, danh sách finding code, severity, scan report (mục 07–08).
IsleWardenJson.cs	JSON dùng chung: camelCase, enum dạng string, giữ nguyên tiếng Việt.
Protocol/Login.cs · Protocol/Access.cs	PKCE, code lỗi đăng nhập, các gate và code chặn (mục 09).

Phía server (Python, thư mục `server/islewarden_server/`): log nằm ở `records.py` + `db.py` (bảng `reports`, `findings`), `risk.py`, `discord.py`; đăng nhập ở `login/` (`steam.py`, `discord_api.py`, `discord_gate.py`, `pending.py`, `service.py`). Phía launcher: `LoginCommand.cs`, `LoopbackListener.cs` trong `launcher/IsleWarden.Agent/`.

Build, test và chạy thử

Build và chạy test của phần phát hiện

```
dotnet build launcher/IsleWarden.slnx
dotnet test launcher/IsleWarden.Core.Tests
```

Quét thử máy này, không cần server

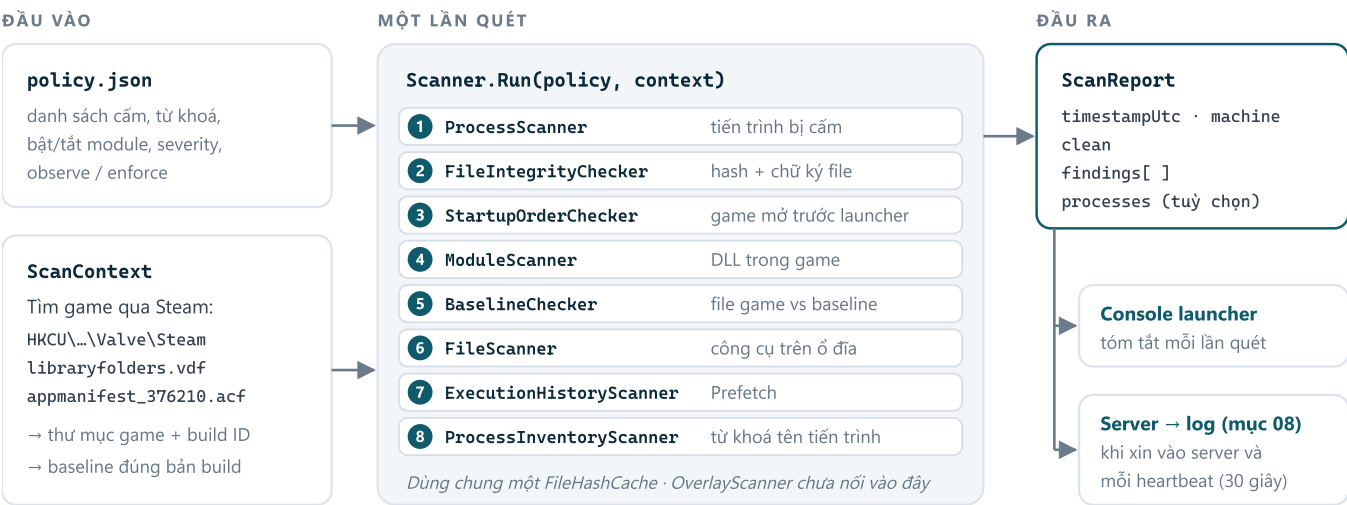
```
IsleWarden.Agent.exe scan policy.json --once
# in report JSON; exit code:
# 0 = sạch · 1 = có finding · 2 = lỗi policy
```

Yêu cầu: .NET SDK 10 cho launcher và thư viện phát hiện; server là Python ≥ 3.10. Mọi API chỉ có trên Windows (Registry, WinVerifyTrust, WMI, Prefetch) đều được bọc bằng `OperatingSystem.IsWindows()`. Phía người chơi cần Windows 10/11 x64 và **không cần quyền admin**, trừ module Prefetch.

“Policy mẫu” nhắc tới trong tài liệu là `config/server-policy.example.json` — bản server gửi cho launcher; `config/policy.example.json` là bản rút gọn để quét local.

02 Kiến trúc Scanner

Mọi module đều làm theo một kiểu: nhận policy, kiểm tra máy, trả ra danh sách Finding. Không module nào tự chặn người chơi — chặn hay không do chế độ observe/enforce và ngưỡng severity quyết định (mục 07).



Hình 1. Một lần quét. Thứ tự các module đúng như trong `Scanner.Run`; trước module 1, Scanner kiểm tra có tìm được thư mục game không (khi policy cần) và ghi `game-not-found` nếu không.

Khi nào quét

Launcher quét một lần khi xin vào server (report đi kèm yêu cầu), rồi quét lại ở **mỗi heartbeat** (mặc định 30 giây) suốt lúc chơi. Một object `Scanner` được giữ suốt phiên, nên `FileHashCache` bên trong nó có tác dụng: file game chỉ bị hash ở vài lần quét đầu, các lần sau gần như chỉ đọc thông tin file.

Nguyên tắc thiết kế

1

Không phán xử

Module chỉ trả về finding. Chặn hay không do chế độ + ngưỡng quyết định; đổi rule chỉ cần sửa policy, không phải build lại.

2

Privacy by design

Khớp theo tên/hash trước khi đọc bất cứ thứ gì. Thứ không khớp bị bỏ ngay: không ghi, không gửi.

3

Không đoán

Không đọc được thì bỏ qua hoặc ghi info, không kết luận. Một con số đoán sai có thể khiến người chơi bị phạt oan.

4

Có giới hạn

Giới hạn thời gian, số file và dung lượng hash mỗi lần quét, để không làm giật game.

5

Không can thiệp máy

Không tắt, xoá hay sửa gì. Mở tiến trình với quyền tối thiểu; đọc file ở chế độ share để không can game.

Gắn vào launcher khác

```
var policy = IsleWardenJson.LoadPolicy("policy.json");
var context = ScanContext.Resolve(policy, launcherStartedUtc); // tìm game, build ID
var scanner = new Scanner(); // tạo một lần, dùng cả phiên
var report = scanner.Run(policy, context); // ScanReport → gửi đi / ghi log
```

Gọi `scanner.Run` ở mỗi lần quét để cache hash có tác dụng. `launcherStartedUtc` là mốc cho module kiểm tra thứ tự khởi động (3.4). Nguồn dữ liệu (tiến trình, module) đi qua interface `IProcessSource`, `IModuleSource`, nên test được bằng dữ liệu giả, không cần game.

03 Phát hiện qua tiến trình

Bốn module xem những gì đang chạy: công cụ bị cấm, tên đáng ngờ, DLL lạ trong game, và thứ tự mở game/launcher.

3.1 Tiến trình bị cấm

Bật trong policy mẫu

Source code: `ProcessScanner.cs` · `ProcessSource.cs`

Phát hiện gì	Tiến trình đang chạy có tên nằm trong <code>blockedProcesses</code> — Cheat Engine, ArtMoney, Xenos, Extreme Injector...
Cách làm	Liệt kê tiến trình, chuẩn hoá tên (bỏ khoảng trắng, chữ thường, bỏ đuôi <code>.exe</code>) rồi so với danh sách. Đường dẫn file lấy bằng <code>OpenProcess(PROCESS_QUERY_LIMITED_INFORMATION)</code> + <code>QueryFullProcessImageNameW</code>: quyền tối thiểu, không đọc bộ nhớ, dùng được cả với tiến trình được bảo vệ hoặc khác 32/64-bit.
Tuỳ chọn SHA-256	Nếu rule có danh sách <code>sha256</code> , chỉ báo khi hash của file thực thi khớp — phần mềm vô hại trùng tên không bị flag. Không đọc được file thì bỏ qua: không có bằng chứng thì không báo.
Finding code	<code>blocked-process</code> — severity theo rule, mặc định HIGH . Detail: reason + đường dẫn file.

```
"blockedProcesses": [  
  { "name": "cheatengine-x86_64", "reason": "Cheat Engine", "severity": "high" },  
  { "name": "xenos64", "reason": "Xenos DLL injector", "severity": "high",  
    "sha256": ["<hash của bản đã biết>"] },  
  { "name": "x64dbg", "reason": "Debugger, cần xem xét", "severity": "medium" }  
]
```

3.2 Từ khoá trong tên tiến trình

Bật trong policy mẫu

Source code: `ProcessInventoryScanner.cs`

Phát hiện gì	Tiến trình có tên chứa từ khoá gợi ý công cụ gian lận (aimbot, wallhack, injector, spoofer...) — bắt được cả công cụ chưa có trong danh sách cấm.
Cách làm	Khớp substring, không phân biệt hoa thường. Từ khoá ngắn hơn <code>minKeywordLength</code> (mặc định 4) bị bỏ vì khớp quá rộng — “esp” sẽ khớp cả “respondus”. Danh sách <code>allow</code> bỏ qua các tên đã biết là vô hại. Mỗi tên chỉ báo một lần dù có nhiều tiến trình trùng tên. Tuỳ chọn <code>reportRunningProcesses</code>: gửi kèm danh sách tên tiến trình đang chạy (trường <code>processes</code> của <code>report</code>) để admin tra cứu. Chỉ tên — không bao giờ gửi đường dẫn, command line (có thể chứa token, mật khẩu) hay tiêu đề cửa sổ.
Finding code	<code>suspicious-process-name</code> — severity theo từ khoá, mặc định LOW ; policy mẫu nâng lên MEDIUM cho từ khoá mạnh như aimbot, wallhack. Detail: từ khoá “aimbot”: lý do.
Chống báo nhầm	Từ khoá chỉ là heuristic: nhiều phần mềm hợp lệ có “trainer”, “unlocker”, “inject” trong tên. Để severity low/medium cho admin xem; đừng đặt cao tới mức tự chặn.

3.3 DLL nạp vào tiến trình game

Tắt mặc định

Source code: `ModuleScanner.cs` · `ModuleSource.cs`

Phát hiện gì	DLL bị cấm, hoặc DLL nạp từ thư mục đáng ngờ (%TEMP%, \Downloads\) vào tiến trình TheIsleClient-Win64-Shipping — dấu hiệu inject DLL.
Cách làm	Tìm tiến trình game theo <code>gameProcessName</code> , đọc danh sách module (tên + đường dẫn). <code>blockedModules</code> khớp theo tên, tùy chọn thêm SHA-256 như 3.1. <code>suspiciousPaths</code> khớp substring trong đường dẫn (có expand biến môi trường).
EasyAntiCheat	Game chạy dưới EAC nên việc đọc module có thể bị từ chối. Khi đó chỉ ghi <code>module-scan-unavailable</code> (<code>INFO</code>), không kết luận, và nhớ PID đó để không mở handle vào game ở mỗi lần quét.
Finding code	<code>blocked-module</code> theo rule, mặc định <code>HIGH</code> · <code>suspicious-module</code> theo <code>suspiciousSeverity</code> , mặc định <code>MEDIUM</code> · <code>module-scan-unavailable</code> <code>INFO</code> .
Lưu ý	Chạy thử trên máy test cùng EAC trước khi bật cho người chơi (<code>moduleScan.enabled</code>).

3.4 Game mở trước launcher

Bật trong policy mẫu

Source code: `StartupOrderChecker.cs`

Phát hiện gì	Game đã chạy từ trước khi mở launcher — kiểu “inject cheat trước, mở launcher sau cho có”.
Cách làm	So thời điểm khởi động tiến trình game với thời điểm khởi động launcher, cho phép lệch <code>toleranceSeconds</code> (mặc định 5 giây). Không đọc được thời điểm thì bỏ qua. Nếu launcher khởi động lại giữa chừng và nối lại lease cũ, mốc so sánh vẫn là launcher ban đầu, nên không báo nhầm.
Finding code	<code>game-started-before-launcher</code> — mặc định <code>MEDIUM</code> . Detail: <code>game=<thời điểm>; launcher=<thời điểm></code> .

04 Phát hiện qua file game

Hai module bổ sung cho nhau: 4.1 kiểm tra kỹ vài file quan trọng bằng hash và chữ ký số; 4.2 so **toàn bộ** thư mục game với bộ hash lấy từ một bản cài sạch.

4.1 File được bảo vệ: hash và chữ ký số

Bật trong policy mẫu

Source code: `FileIntegrityChecker.cs` · `AuthenticodeVerifier.cs`

Phát hiện gì	File quan trọng (ví dụ <code>TheIsle.exe</code>) bị thiếu, bị sửa, mất chữ ký số hoặc do bên khác ký.
Hash	Đường dẫn hỗ trợ <code>{GameDir}</code> và biến môi trường. Nếu rule có danh sách <code>sha256</code> (nhiều giá trị = cho phép nhiều phiên bản) thì so SHA-256.
Chữ ký số	Khi bật <code>requireSignature</code> : gọi <code>WinVerifyTrust (WINTRUST_ACTION_GENERIC_VERIFY_V2)</code> để kiểm tra certificate chain tới trusted root, tính toàn vẹn của file và timestamp — chữ ký có timestamp vẫn hợp lệ sau khi certificate hết hạn. Không check revocation online (chỉ dùng cache) để không làm chậm máy người chơi. <code>expectedSigner</code> là chuỗi phải có trong subject của certificate, ví dụ “EasyAntiCheat Oy”.
Lưu ý	Kiểm tra ngày 26/09/2026: <code>TheIsle.exe</code> được EasyAntiCheat Oy ký hợp lệ (đúng như policy mẫu), còn <code>TheIsleClient-Win64-Shipping.exe</code> không có chữ ký số — đừng bật <code>requireSignature</code> cho file này, hãy kiểm tra nó bằng hash hoặc baseline (4.2).

Kết quả	Finding code	Severity
File không tồn tại	file-missing	MEDIUM
Hash không khớp danh sách cho phép	file-tampered	HIGH
Không đọc được file để hash	file-unreadable	LOW
Không có chữ ký, hoặc định dạng file không hỗ trợ ký	unsigned-file	HIGH
Bị sửa sau khi ký · root không tin cậy · certificate chain đứt · certificate hết hạn mà không có timestamp · certificate bị revoke · bị đánh dấu không tin cậy	invalid-signature	HIGH
Chữ ký hợp lệ nhưng signer khác expectedSigner	wrong-signer	HIGH
Lỗi khác, không kiểm tra được	signature-check-failed	LOW

4.2 So toàn bộ thư mục game với baseline

Bật trong policy mẫu

Source code: [Baseline.cs](#) · [BaselineChecker.cs](#) · [FileHashCache.cs](#)

Phát hiện gì	File game bị sửa, bị thiếu, và file lạ được thêm vào — ví dụ một .pak mod xoá cỏ, sương mù để nhìn xuyên, hay một .dll proxy đặt cạnh file exe.
Tạo baseline	Admin chạy <code>IsleWarden.Agent baseline --out <buildId>.json</code> trên một bản cài sạch: hash mọi file khớp *.exe *.dll *.pak *.utoc *.ucas *.sig, bỏ qua thư mục EasyAntiCheat (EAC tự cập nhật thư mục này). Game cập nhật thì phải tạo baseline mới cho build mới.
Chọn đúng build	Build ID đọc từ <code>appmanifest_376210.acf</code> của Steam; launcher lấy baseline đúng build đó (từ server, hoặc file <code>local baselines/{BuildId}.json</code>). Lệnh build → <code>baseline-outdated</code> ; chưa có → <code>baseline-unavailable</code> — đều INFO , bỏ qua so sánh chứ không kết luận.
So từng file	File nhỏ trước, để exe/dll luôn được kiểm ngay lần quét đầu. Thiếu → <code>file-missing</code> MEDIUM . Khác kích thước → <code>file-tampered</code> (không cần hash). Khác hash → <code>file-tampered</code> theo <code>baseline.severity</code> , mặc định HIGH . Không đọc được → <code>file-unreadable</code> LOW .
File lạ	Liệt kê thư mục game theo cùng mẫu include/exclude (kể cả file ẩn/hệ thống, bỏ qua symlink/junction); file không có trong baseline → <code>unexpected-file</code> MEDIUM . Tắt được bằng <code>reportUnexpectedFiles: false</code> .
Giới hạn + cache	Mỗi lần quét hash tối đa <code>maxHashMegabytesPerScan</code> (mặc định 512 MB) và luôn hash ít nhất một file; phần còn lại → <code>baseline-pending</code> INFO , kiểm ở các lần sau. Bản build 24664737 có 109 file khớp mẫu, khoảng 9,35 GB — riêng ba file .ucas đã gần 9 GB, nên chúng được hash rải qua vài lần quét đầu. FileHashCache nhớ SHA-256 theo (đường dẫn, kích thước, thời điểm sửa): file không đổi thì không hash lại. Cache nằm trong RAM, nên mỗi lần mở launcher sẽ hash lại từ đầu. File được mở với <code>FileShare.ReadWrite Delete</code> để vẫn hash được khi game đang mở file.

```
{
  "version": 1, "appId": "376210", "buildId": "24664737",
  "include": ["*.exe", "*.dll", "*.pak", "*.utoc", "*.ucas", "*.sig"],
  "exclude": ["EasyAntiCheat"],
  "files": [
    { "path": "TheIsle.exe",
      "size": 3946736, "sha256": "..." },
    { "path": "TheIsle\\Binaries\\Win64\\TheIsleClient-Win64-Shipping.exe",
      "size": 204050944, "sha256": "..." },
    { "path": "TheIsle\\Content\\Paks\\pakchunk0-WindowsClient.ucas",
      "size": 4041676576, "sha256": "..." }
  ]
}
```

05 Dấu vết công cụ trên máy

Người chơi có thể tắt công cụ trước khi mở launcher, khi đó quét tiến trình không thấy gì. Hai module dưới đây tìm dấu vết còn lại: file công cụ còn nằm trên ổ đĩa, và Prefetch — nơi Windows ghi lại chương trình đã từng chạy.

5.1 File công cụ gian lận trên ổ đĩa

Bật trong policy mẫu

Source code: [FileScanner.cs](#)

Phát hiện gì	File của công cụ đã biết, theo tên chính xác (ví dụ IsleUnlocker.exe), trong các thư mục chọn sẵn — kể cả khi công cụ không chạy.
Thư mục	Token {Downloads}, {Desktop}, {Temp}, {GameDir}, {Documents}, {AppData}, {LocalAppData}, {ProgramFiles}, {ProgramFilesX86}, hoặc biến môi trường.
Cách làm	Duyệt BFS, chỉ so tên file với danh sách (không phân biệt hoa thường). File không khớp bị bỏ ngay — không ghi lại, không gửi đi. Chỉ file đã khớp tên mới bị đọc để hash, và chỉ khi rule có sha256. Không đi theo symlink/junction (tránh vòng lặp, tránh ra ngoài cây thư mục); một file thấy qua hai thư mục lồng nhau chỉ báo một lần.
Giới hạn cứng	maxDepth 2 · maxFilesExamined 20.000 · timeoutSeconds 5 — dùng chung cho mọi thư mục của một lần quét, nên không bao giờ quét cả ổ đĩa.
Finding code	<code>blocked-file</code> — mặc định MEDIUM : có file chỉ chứng minh người chơi có công cụ, chưa chứng minh đã <i>dùng</i> (có thể tải về rồi để đó). Muốn chặn thẳng thì đặt high.

5.2 Prefetch: lịch sử chạy chương trình

Tắt mặc định

Source code: [ExecutionHistoryScanner.cs](#) · [PrefetchReader.cs](#)

Mỗi khi một chương trình chạy, Windows để lại file C:\Windows\Prefetch\TÊN.EXE-XXXXXXX.pf, ghi số lần chạy và lần chạy gần nhất. Module này đọc các file đó để thấy công cụ **đã chạy trong 7 ngày gần đây** (lookbackDays) rồi được tắt trước khi mở launcher.

1

Lọc theo tên trước khi mở file

Tên chương trình nằm ngay trong tên file .pf (hậu tố 8–16 chữ số hex là hash đường dẫn). Chỉ file khớp **programs** (tên chính xác) hoặc **keywords** (≥ 4 ký tự) mới được mở; mọi chương trình khác không bị mở, ghi hay gửi.

2

Giải nén và đọc

Windows 10/11 nén .pf bằng XPRESS Huffman (header "MAM"); code giải nén bằng API công khai `RtlDecompressBufferEx` của `ntdll`, kiểm tra magic "SCCA", rồi đọc tên chương trình, format version (17, 23, 26, 30, 31), lần chạy gần nhất và số lần chạy.

3

Kiểm tra giá trị có hợp lý không

Giá trị đọc theo offset phải hợp lý: thời điểm từ năm 2010 đến hiện tại + 1 ngày, số lần chạy 1–1.000.000. Sai thì dùng thời điểm ghi của file .pf hoặc để trống. Offset số lần chạy của Windows 11 (format 31) chưa được xác nhận nên để trống thay vì đoán.

4

Chỉ tính N ngày gần nhất

Chỉ tính lần chạy trong `lookbackDays` ngày; mỗi chương trình báo một lần. Giới hạn an toàn: file .pf lớn hơn 4 MB bị bỏ, dữ liệu giải nén tối đa 32 MB, tối đa 4.096 file hoặc 5 giây mỗi lần quét.

Finding code	Severity mặc định	Khi nào
<code>executed-tool</code>	MEDIUM	Chương trình trong <code>programs</code> đã chạy trong <code>lookbackDays</code> ngày gần đây. Detail ví dụ: lần chạy gần nhất 2026-09-25 14:02 UTC – 3 lần – Isle Unlocker.
<code>suspicious-executed-name</code>	LOW	Tên chương trình chứa từ khoá (heuristic).
<code>execution-history-unavailable</code>	INFO	Không đọc được Prefetch — thường do launcher không chạy với quyền admin.
<code>execution-history-off</code>	INFO	Prefetch bị tắt (<code>EnablePrefetcher = 0</code>) — có thể do tinh chỉnh máy, cũng có thể là cách xóa dấu vết.

Cần quyền admin và phải ghi vào disclosure trước khi bật

Chỉ Administrators đọc được thư mục Prefetch; không có quyền thì module này chỉ ghi `info`, không kết luận. Đây là lịch sử chạy phần mềm của máy người chơi, nên trước khi bật phải thêm câu tương ứng vào `disclosure` và tăng `disclosureVersion` để mọi người chơi đồng ý lại.

06

Overlay lạ và HWID

6.1 Cửa sổ lạ phủ lên game

Đã viết · chưa nối vào ScannerSource code: `OverlayScanner.cs`

Phát hiện gì	Cửa sổ của tiến trình khác đang phủ lên cửa sổ game với window style đặc trưng của overlay — thường là ESP/radar vẽ đè lên game.
Cách làm	EnumWindows lấy mọi top-level window đang hiển thị: PID, tọa độ, extended style, tiêu đề. Cửa sổ game là cửa sổ hiển thị lớn nhất của tiến trình game; chưa có cửa sổ game thì không kết luận. Ứng viên là cửa sổ của tiến trình khác, không thuộc <code>AllowedProcesses</code> (steam, discord, obs64...) hay tiến trình hệ thống Windows (explorer, dwm, textinputhost, ctfmon...), có <code>WS_EX_TOPMOST</code> / <code>WS_EX_LAYERED</code> / <code>WS_EX_TRANSPARENT</code> (topmost, trong suốt, click-through) và phủ $\geq 15\%$ diện tích cửa sổ game (<code>MinOverlapFraction</code>).

Finding code	<code>foreign-overlay</code> — mặc định MEDIUM . Detail: <code>title="..."</code> ; phủ 42%; <code>topmost+layered+click-through</code> .
Giới hạn	Chỉ bắt overlay dạng cửa sổ; overlay vẽ qua hook DirectX không phải cửa sổ nên thuộc phạm vi module DLL (3.3). Dễ báo nhầm với Steam, Discord, bộ gõ, phần mềm quay màn hình — luôn chạy observe với allowlist trước.

Để nối vào Scanner: ba thay đổi nhỏ

1. Chuyển `OverlayScanRule` vào `Policy` (hiện đang đứng riêng trong `OverlayScanner.cs`).
2. Thêm `foreign-overlay` vào `FindingCodes`.
3. Gọi `OverlayScanner.Scan` trong `Scanner.Run`.

Nên thêm hai tín hiệu mà overlay hiện đại hay dùng để ẩn: `GetWindowDisplayAffinity` (cửa sổ tự giấu khỏi screenshot) và `DwmGetWindowAttribute(DWMWA_CLOAKED)`.

6.2 HWID: ban theo máy

Gửi khi đăng nhập

Source code: `DeviceFingerprint.cs` (`DeviceFingerprintCollector`) · `WmiIdentifiers.cs`

Mục đích: ban gắn với **chiếc máy** chứ không chỉ tài khoản — tạo tài khoản Steam mới trên cùng máy vẫn bị chặn.

Thành phần	Lấy từ	Ghi chú
<code>machineGuid</code>	Registry HKLM\SOFTWARE\Microsoft\Cryptography\MachineGuid (view 64-bit)	Đôi khi cài lại Windows
<code>mac</code>	Card mạng đang hoạt động, ưu tiên card dây, bỏ loopback/tunnel	Đổi được bằng phần mềm
<code>diskSerial</code>	WMI <code>Win32_DiskDrive</code> : ổ chứa Windows, không thì ổ cố định đầu tiên; bỏ ổ USB	Ổ định
<code>baseboardSerial</code>	WMI <code>Win32_BaseBoard.SerialNumber</code>	Máy ảo thường để trống
<code>biosSerial</code>	WMI <code>Win32_BIOS.SerialNumber</code>	Máy ảo thường để trống
<code>cpuId</code>	WMI <code>Win32_Processor.ProcessorId</code>	Trùng giữa các CPU cùng đời, nên không dùng để ban hay so khớp

- Giá trị rác OEM hay để (To be filled by O.E.M., Default string, 0, None...) bị loại. Nguồn nào không đọc được thì bỏ qua, phần còn lại vẫn dùng.
- `DeviceId` = SHA-256 của chuỗi `key=value|...` sắp theo key; không đọc được nguồn nào thì là `UNKNOWN`.
- Launcher gửi fingerprint **một lần, lúc đăng nhập** (mục 09), qua HTTPS. Server không lưu serial thô: chỉ lưu `DeviceId` và HMAC-SHA256(pepper bí mật, "kind:value") của từng thành phần.
- Ban nhầm được Steam ID, device, hoặc **từng linh kiện** (ví dụ serial ổ đĩa), nên thay một linh kiện không thoát được ban. Máy mới trùng linh kiện với máy của Steam ID khác — nhất là tài khoản đang bị ban — được giữ lại chờ admin duyệt, và người chơi không được báo lý do để không “dạy” cách né.
- Tự kiểm: `IsleWarden.Agent.fingerprint` in fingerprint của máy (che bớt giá trị, `--raw` để xem đầy đủ) và không gửi gì.

07 Finding code, severity, observe/enforce

Các mức severity

INFO Ngữ cảnh, không phải cáo buộc: không đọc được Prefetch, chưa có baseline... Không làm report "bắn", không tính vào risk score.	LOW Tín hiệu yếu, heuristic: khớp từ khoá, không đọc được file.	MEDIUM Đáng chú ý, cần người xem: công cụ nằm trên ổ đĩa, file lạ trong thư mục game, game mở trước launcher.	HIGH Bằng chứng mạnh: tiến trình bị cấm đang chạy, file game bị sửa, chữ ký sai.	CRITICAL Dành cho rule admin tự đặt; config mặc định không dùng.
---	---	---	--	--

Report được tính là **sạch** (clean = true) khi không có finding nào từ **LOW** trở lên.

OBSERVE — MẶC ĐỊNH Mọi finding đều được ghi log và gửi cảnh báo, nhưng không chặn ai . Dùng để chạy thử, đo báo nhầm, chỉnh danh sách trước khi siết.	ENFORCE Finding $\geq$ EnforceThreshold (mặc định HIGH) thì từ chối vào server hoặc thu hồi lease đang chơi. Người chơi thấy lý do và support code R- <code><id></code> (mục 08).
--	---

Với ngưỡng mặc định **high**, các tín hiệu heuristic (từ khoá: low; file trên ổ đĩa, Prefetch: medium) không tự chặn được ai — chúng chỉ đưa người chơi vào danh sách cần xem xét. Admin có thể cấp **bypass** cho một Steam ID (streamer, staff): gate anti-cheat được nới, nhưng report vẫn được ghi đầy đủ.

Danh sách finding code

23 code trong FindingCodes, cộng foreign-overlay của OverlayScanner (chưa nổi). Severity có dấu * đổi được trong policy.

Code	Module	Severity	Ý nghĩa
TIẾN TRÌNH			
blocked-process	ProcessScanner	HIGH *	Tiến trình bị cấm đang chạy
suspicious-process-name	ProcessInventoryScanner	LOW *	Tên tiến trình chứa từ khoá đáng ngờ
blocked-module	ModuleScanner	HIGH *	Game đang nạp DLL bị cấm
suspicious-module	ModuleScanner	MEDIUM *	Game nạp DLL từ thư mục đáng ngờ
module-scan-unavailable	ModuleScanner	INFO	Không đọc được danh sách module (thường do EAC)
game-started-before-launcher	StartupOrderChecker	MEDIUM *	Game chạy trước khi mở launcher
FILE GAME			
file-missing	FileIntegrity, Baseline	MEDIUM	Thiếu file được bảo vệ / file có trong baseline
file-tampered	FileIntegrity, Baseline	HIGH	Hash hoặc kích thước không khớp (baseline: đổi được)
file-unreadable	FileIntegrity, Baseline	LOW	Không đọc được file để hash
unexpected-file	BaselineChecker	MEDIUM	File lạ trong thư mục game

Code	Module	Severity	Ý nghĩa
<code>unsigned-file</code>	FileIntegrityChecker	HIGH	File không có chữ ký số
<code>invalid-signature</code>	FileIntegrityChecker	HIGH	Chữ ký số không hợp lệ
<code>wrong-signer</code>	FileIntegrityChecker	HIGH	Ký bởi bên không mong đợi
<code>signature-check-failed</code>	FileIntegrityChecker	LOW	Không kiểm tra được chữ ký
<code>game-not-found</code>	Scanner	MEDIUM	Không xác định được thư mục game khi policy cần
<code>baseline-unavailable</code>	BaselineChecker	INFO	Chưa có baseline cho bản game này
<code>baseline-outdated</code>	BaselineChecker	INFO	Baseline không khớp bản game đang cài
<code>baseline-pending</code>	BaselineChecker	INFO	Còn file lớn sẽ kiểm ở các lần quét sau
DẤU VẾT TRÊN MÁY			
<code>blocked-file</code>	FileScanner	MEDIUM *	File công cụ gian lận trên ổ đĩa
<code>executed-tool</code>	ExecutionHistory	MEDIUM *	Công cụ đã chạy trong N ngày gần đây
<code>suspicious-executed-name</code>	ExecutionHistory	LOW *	Chương trình đã chạy có tên chứa từ khoá
<code>execution-history-unavailable</code>	ExecutionHistory	INFO	Không đọc được Prefetch (thiếu quyền admin)
<code>execution-history-off</code>	ExecutionHistory	INFO	Prefetch đang bị tắt trên máy
CHƯA NỐI VÀO SCANNER			
<code>foreign-overlay</code>	OverlayScanner	MEDIUM *	Cửa sổ lạ phủ lên game

08 Ghi log: từ finding đến bằng chứng

Mỗi finding là một bản ghi có cấu trúc; các finding của một lần quét gom thành một scan report. Report được lưu lại để admin tra đúng bằng chứng khi người chơi khiếu nại.

8.1 Một finding

Trường	Nội dung	Dùng để
code	Loại finding, ví dụ <code>blocked-process</code> (danh sách trong <code>FindingCodes</code>)	Lọc, thống kê, xử lý tự động
severity	<code>info</code> · <code>low</code> · <code>medium</code> · <code>high</code> · <code>critical</code>	Quyết định chặn (enforce), ngưỡng cảnh báo Discord, risk score
message	Câu tiếng Việt cho người đọc	Hiển thị cho admin và người chơi
detail	Bằng chứng kỹ thuật, có thể trống	Đường dẫn file, hash, signer, thời điểm, từ khoá đã khớp

8.2 Scan report

Mỗi lần quét tạo một ScanReport — thứ launcher gửi lên server và là bản log gốc được lưu.

```
{
  "timestampUtc": "2026-09-25T18:57:42.2708001+00:00",
  "machine": "DESKTOP-PLAYER01",
  "clean": false,
  "findings": [
    { "code": "blocked-process", "severity": "high",
      "message": "Phát hiện tiến trình bị cấm: cheatengine-x86_64 (PID 8124)",
      "detail": "Cheat Engine - C:\\Program Files\\Cheat Engine 7.5\\cheatengine-x86_64.exe" },
    { "code": "blocked-file", "severity": "medium",
      "message": "Tìm thấy công cụ gian lận trên máy: IsleUnlocker.exe",
      "detail": "Isle Unlocker - C:\\Users\\player\\Downloads\\IsleUnlocker.exe" },
    { "code": "execution-history-unavailable", "severity": "info",
      "message": "Không đọc được nhật ký thực thi của Windows.",
      "detail": "thư mục Prefetch cần quyền quản trị để đọc" }
  ],
  "processes": null
}
```

Định dạng lấy từ một lần quét thật ngày 26/09/2026; tên máy, đường dẫn và finding `blocked-process` là minh họa. Trong request gửi lên server và trong database, tên trường là camelCase; lệnh `scan` in cùng nội dung với tên trường dạng PascalCase. `processes` chỉ có giá trị khi bật `reportRunningProcesses` (3.2).

8.3 Log tại máy người chơi

Launcher in tóm tắt mỗi lần quét ra console. Nó **không ghi file log riêng** trên máy người chơi — bản log có giá trị là bản server nhận. Cần lưu local để thử thì redirect output của scan `--once` vào file.

```
[01:57:42] Quét: CÓ PHÁT HIỆN (3 mục)
- [High] blocked-process: Phát hiện tiến trình bị cấm: cheatengine-x86_64 (PID 8124)
- [Medium] blocked-file: Tìm thấy công cụ gian lận trên máy: IsleUnlocker.exe
- [Info] execution-history-unavailable: Không đọc được nhật ký thực thi của Windows.
```

Khi bị chặn (enforce), launcher in từng gate đã xét, gate bị chặn, và **support code** trở tới report trong log:

```
[ok]      Thiết bị
[ok]      Lệnh cấm
[ok]      Discord - playerName
[ok]      Thông báo - iw-v2
[CHẶN]    Anti-cheat
```

Bị chặn ở bước Anti-cheat: Phát hiện phần mềm không được phép trên máy. Tắt nó rồi thử lại.
Chi tiết: `blocked-process`: Phát hiện tiến trình bị cấm: `cheatengine-x86_64` (PID 8124)
Mã tra cứu (gửi admin khi khiếu nại): **R-1042**
Mã lỗi: `anticheat-blocked`

8.4 Log được lưu ở đâu

Nơi lưu	Ghi gì	Khi nào
Bảng reports	Một dòng mỗi report: <code>lease</code> , <code>device</code> , Steam ID, <code>clean</code> , <code>findings_json</code> (bản gốc), <code>processes_json</code> (nếu bật), thời điểm nhận. Id của dòng chính là support code <code>R-<id></code> .	Mỗi lần xin vào (kể cả khi bị chặn ở gate anti-cheat) và mỗi heartbeat

Nơi lưu	Ghi gì	Khi nào
Bảng findings	Một dòng mỗi finding, tách từ findings_json: code, severity, severity_rank (0–4), message, detail, steam_id, received_utc. Có index theo (Steam ID, thời gian) và (code, thời gian).	Cùng transaction với reports; xoá report thì xoá luôn
sessions.end_code / end_reason	Vì sao một lease kết thúc: anticheat-blocked kèm [R-<id>] và các finding vượt ngưỡng, lease-expired, banned...	Khi lease bị thu hồi, hết hạn hoặc được trả lại
admin_actions, ban_evidence	Log thao tác của admin kèm report làm bằng chứng; tóm tắt bằng chứng của ban được giữ lại cả khi report gốc đã bị dọn.	Khi admin xử lý
Discord webhook	Tối đa 10 finding $\geq$ Discord.MinSeverity (mặc định medium) mỗi report, có đánh dấu nếu người chơi đang được bypass; cùng các sự kiện: chặn do ban, thu hồi lease, mất tín hiệu launcher, máy mới cần duyệt.	Ngay khi nhận report hoặc sự kiện

Heartbeat 30 giây nghĩa là khoảng 120 report mỗi giờ cho mỗi người chơi, phần lớn lặp lại — nên đặt thời hạn lưu và dọn report cũ định kỳ; bằng chứng gắn với ban vẫn còn nhờ ban_evidence.

8.5 Risk score

RiskScorer (server/islewarden_server/risk.py) gom log của một người chơi thành một con số để sắp thứ tự cần xem xét. Ba quy tắc:

1 Gộp theo (code, ngày)

Heartbeat làm một finding lặp hàng trăm lần mỗi phiên; đếm từng lần sẽ thổi phồng điểm.

2 info = 0 điểm

Ngữ cảnh, không phải cáo buộc.

3 Giảm dần theo thời gian

Half-life 7 ngày: finding tháng trước không giữ người chơi ở mức cao mãi.

Score = $\sum \text{trọng số} \times 0,5^{\text{tuổi (ngày)} / 7}$, tối đa 100, với trọng số low 1 · medium 5 · high 20 · critical 40. Band: 0 clean · dưới 10 low · dưới 35 medium · từ 35 high. Ví dụ: blocked-process (high) cách đây 3 ngày $\approx 14,9$ điểm, cộng executed-tool (medium) hôm nay 5 điểm $\approx 20 \rightarrow$ band medium. Risk score **không bao giờ tự chặn ai**; nó chỉ sắp thứ tự, kèm tối đa 4 lý do (code, số ngày, lần gần nhất) để admin giải thích với người chơi.

8.6 Truy vấn log mẫu (SQLite)

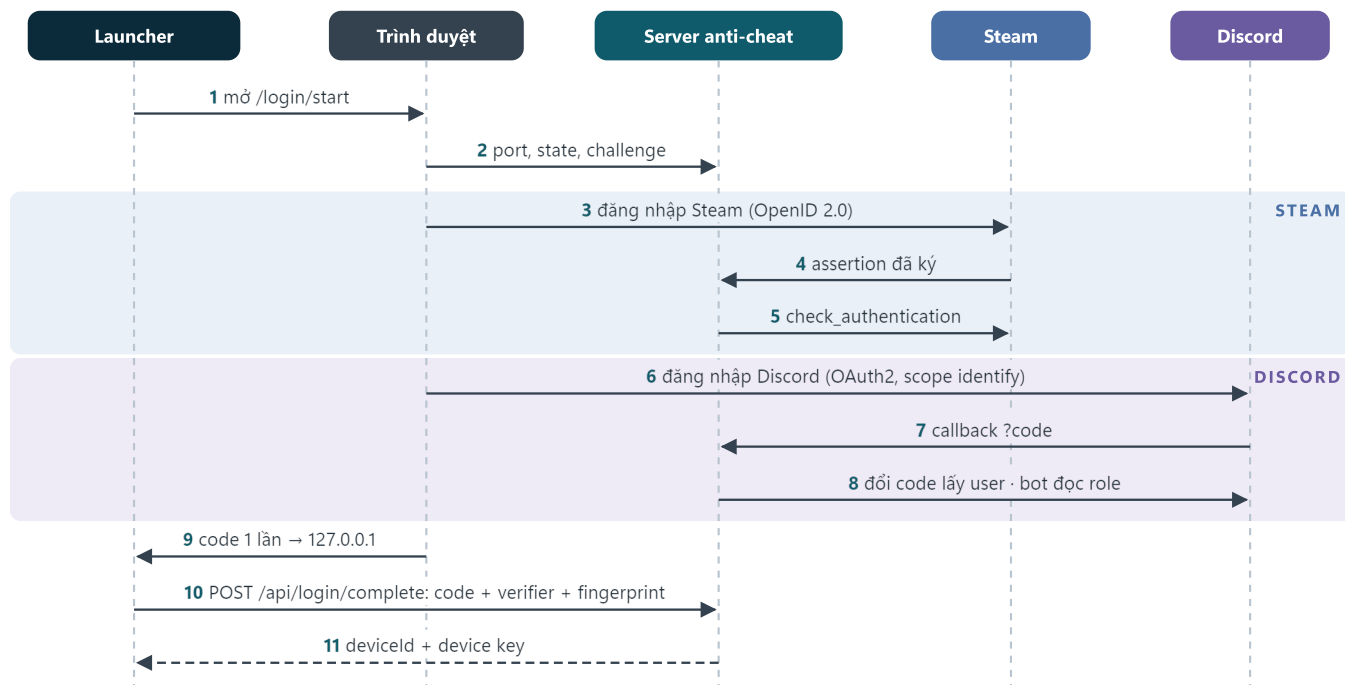
```
-- 50 finding gần nhất của một người chơi
SELECT received_utc, code, severity, message, detail
FROM findings WHERE steam_id = '76561198000000001'
ORDER BY received_utc DESC LIMIT 50;

-- Code nào xuất hiện ở nhiều người chơi nhất trong 7 ngày (bỏ info)
SELECT code, COUNT(DISTINCT steam_id) AS nguoi_choi, COUNT(*) AS so_lan
FROM findings
WHERE severity_rank >= 1
AND received_utc >= strftime('%Y-%m-%dT%H:%M:%S', 'now', '-7 days')
GROUP BY code ORDER BY nguoi_choi DESC;

-- Người chơi gửi support code R-1042
SELECT * FROM reports WHERE id = 1042;
```

09 Đăng nhập Steam + Discord, cấp quyền vào server

Trước khi quét, server cần biết người chơi là ai. Mỗi máy đăng nhập một lần: **Steam** chứng minh người chơi sở hữu Steam ID nào, **Discord** chứng minh họ ở trong Discord của server và có role được phép chơi. Xong bước này launcher mới nhận device key.



Hình 2. Đăng nhập theo chuẩn cho native app (RFC 8252: redirect về loopback + PKCE). Bước 3–8 diễn ra trong trình duyệt; server redirect giữa các bước.

STEAM · BƯỚC 3–5

Server chỉ nhận assertion khi: `return_to` đúng địa chỉ của chính lượt đăng nhập, đủ các trường bắt buộc được ký, Steam xác nhận lại chữ ký (`check_authentication`), và `claimed_id` đúng dạng SteamID64. Không cần Steam API key.

DISCORD · BƯỚC 6–8

Token của người chơi (scope `identify`) chỉ dùng một lần để biết họ là ai, không lưu. Role được đọc bằng bot của ứng dụng (bot ở trong guild, không cần quyền gì), nên kiểm lại được về sau.

VỀ LAUNCHER · BƯỚC 9–11

Redirect cuối chỉ tới được `127.0.0.1` của chính máy đã đăng nhập, và chỉ launcher giữ PKCE verifier mới đổi được code — gửi link đăng nhập cho người khác không chiếm được tài khoản.

- **Một Discord ↔ một Steam ID:** một người có role không thể “bảo lãnh” nhiều tài khoản Steam; đổi liên kết là việc của admin. Lỗi đăng nhập có code riêng: `login-expired`, `steam-login-failed`, `discord-login-failed`, `discord-linked-elsewhere`, `steam-linked-elsewhere`.
- Lượt đăng nhập đang dở tồn tại tối đa 10 phút. Device key trả về đúng một lần: server chỉ lưu hash, launcher giữ bằng DPAPI của Windows. Fingerprint máy (6.2) được gửi ở bước 10.

Cấp quyền vào server

Khi người chơi vào chơi, launcher quét một lần rồi gửi report kèm yêu cầu. Server xét các gate **theo thứ tự** và dừng ở gate đầu tiên chặn, nên người chơi biết chính xác gate nào đang chặn mình:

#	Gate	Chặn khi	Code
1	Device	Chưa đăng nhập / device key sai · máy bị từ chối · máy đang chờ duyệt	device-unknown device-rejected device-pending
2	Ban	Steam ID, device hoặc một linh kiện nằm trong ban list	banned
3	Discord	Chưa liên kết · không còn trong Discord · không có role	discord-not-linked discord-not-member discord-role-missing
4	Consent	Chưa đồng ý disclosure phiên bản hiện tại	consent-required
5	Anti-cheat	Enforce và có finding $\geq$ ngưỡng	anticheat-blocked

Qua hết năm gate thì server cấp **lease** và thêm Steam ID vào whitelist của game server. Trong lúc chơi, mỗi heartbeat (30 giây) mang theo scan report mới và được xét lại: ban, trạng thái máy, role Discord (hỏi lại Discord mỗi 10 phút; Discord lỗi thì dùng kết quả gần nhất để không khoá oan cả server), và anti-cheat. Vi phạm thì lease bị thu hồi và Steam ID bị gỡ khỏi whitelist; tắt launcher hoặc mất tín hiệu quá 75 giây cũng mất lease.

10 Wall-hack: module nào bắt được

Cách làm wall-hack	Module	Trạng thái
Mod .pak/.utoc/.ucas xoá cò, sượng mù... đặt vào thư mục game, hoặc sửa file game có sẵn	BaselineChecker: unexpected-file, file-tampered	Có
Công cụ ESP đã biết chạy song song, hoặc tên có từ khoá như wallhack	ProcessScanner, ProcessInventoryScanner; FileScanner và Prefetch nếu đã tắt	Có, theo tên
DLL ESP inject vào game	ModuleScanner	Tắt mặc định; EAC có thể chặn việc đọc
Overlay ESP vẽ đè bằng cửa sổ trong suốt	OverlayScanner	Đã viết, chưa nổi
Chỉnh file cấu hình của game (Engine.ini, GameUserSettings.ini...) để bớt sượng mù, cò	—	Chưa có
Cheat kernel, thẻ DMA, cheat chạy trên máy khác	—	Ngoài tầm user-mode